AP CYBERSECURITY | INVESTIGATION LAB - STUDENT

# LAB 3

## The Mysterious Open Port

Unit 3: Securing Networks | 55 to 70 minutes

### Your role

You are a network security analyst for a fictional robotics lab. A service has appeared on port 8080 and nobody remembers starting it. You will **create the situation yourself on your own practice machine**, observe it with Nmap, read packet evidence, and then decide which firewall rules are correct.

### What you will do

- Scan your own computer before, during, and after a web service runs
- Explain every part of an Nmap command and compare TCP connect and SYN scans
- Read the TCP three-way handshake and a refused connection
- Apply a firewall rule table top to bottom and find a rule-order mistake
- Interpret an IDS port-scan alert

**EXAM LENS**
Every lab follows the same four stages: **Learn the concept, Investigate the evidence, Make a security decision, then Answer AP-style questions.** Commands show you what happened. The skill is deciding what the evidence *proves*, what it *does not prove*, and what to do next.

**COMMON TRAP**
This is a **fictional, controlled** investigation. Never scan, test, or access real school systems, other people's accounts, or any device you do not own or have written permission to use.

Original practice material written in the style of the AP Cybersecurity exam. Not reproduced from College Board.

# Mission Briefing

Part A is hands-on: you will start a tiny web server, scan it, and stop it. Part B uses evidence files from the lab network: two packet captures, a firewall rule table, and an IDS alert.

## Evidence files

| File | What it is |
|---|---|
| **capture_open_port.txt** | Packet list of a connection to a listening port (loopback) |
| **capture_closed_port.txt** | Packet list of a connection to a closed port |
| **firewall_rules.txt** | The lab network's firewall rules, first match wins |
| **ids_alert.txt** | An alert from the lab's intrusion detection system |

## Safety rule

Scan **only your own machine** using `127.0.0.1` (loopback). Never scan school networks, other students' computers, or any system you do not own or have written permission to test.

## Part A setup (use your Kali or Ubuntu practice VM)

```
# Terminal A - make a tiny web page and serve it ONLY to this computer
mkdir -p ~/cybertraining && cd ~/cybertraining
printf '<h1>Robotics Lab Status</h1>\n' > index.html
python3 -m http.server 8080 --bind 127.0.0.1

# Terminal B - scans (run each step as the tasks direct)
nmap -sT -p 22,80,443,8080 127.0.0.1
nmap -sV -p 8080 127.0.0.1
sudo nmap -sS -p 8080 127.0.0.1
```

If Nmap is missing, run `sudo apt install nmap`. Ports 22, 80, and 443 may be open or closed on your VM depending on what is installed; record what **you** see.

**STAGE 1** **Learn**
Be able to explain these before you touch the evidence

- ■ I can name the three packets of the TCP handshake in order (SYN, SYN-ACK, ACK).
- ■ I can explain open, closed, and filtered port states.
- ■ I know common ports: 22 SSH, 53 DNS, 80 HTTP, 443 HTTPS, 8080 alternate web.
- ■ I can apply a firewall rule table by checking every field and stopping at the first match.

STAGE 2

## Investigate

Collect facts. Record what you observe, not what you assume.

**1. Before** starting the server (Terminal A not running), run `nmap -sT -p 22,80,443,8080 127.0.0.1`. Record the state of each port.

**2.** Start the server in Terminal A. In Terminal B run the `-sT` scan again, then `nmap -sV -p 8080 127.0.0.1`. What changed, and what extra information did `-sV` reveal?

**3.** Stop the server with Ctrl+C in Terminal A and scan 8080 again. Explain in one sentence **why** the result changed.

**4.** Decode `nmap -sT -p 22,80,443,8080 127.0.0.1`: explain **each part**. Then explain how `-sS` differs from `-sT` and why `-sS` needed `sudo`.

**5.** Open `capture_open_port.txt`. Label packets 1, 2, and 3 of the handshake, and say what happens in packets 4 to 6.

```
1  54410 -> 8080 [SYN]
2  8080 -> 54410 [SYN, ACK]
3  54410 -> 8080 [ACK]
4  HTTP  GET / HTTP/1.1
5  HTTP  HTTP/1.0 200 OK
6  54410 -> 8080 [FIN, ACK]
```

**6.** Open `capture_closed_port.txt`. How does it differ from the open-port capture, and what does it prove about 8080 at that moment?

```
1  54522 -> 8080 [SYN]
2  8080 -> 54522 [RST, ACK]
```

**7.** Apply `firewall_rules.txt` to each packet. Write the **rule number** that decides and the **action**.

| Packet | Protocol | Port | Source |
|---|---|---|---|
| a | TCP | 22 | 10.0.5.20 |
| b | TCP | 22 | 10.0.9.9 |
| c | TCP | 8080 | 10.0.5.77 |
| d | TCP | 8080 | 203.0.113.50 |

```
1 Allow TCP 443 Any        4 Allow TCP 8080 10.0.5.0/24
2 Allow TCP 22  10.0.5.20  5 Deny  Any Any  203.0.113.50
3 Deny  TCP 22  Any        6 Deny  Any Any  Any
```

**8.** Read `ids_alert.txt`. (a) What activity does it show and what attack phase is it? (b) Rule 5 denies 203.0.113.50, yet port **443** still answered. Explain why, and say how to fix the rules.

```
signature: PORT_SCAN_SEQUENTIAL    source: 203.0.113.50
6 SYN packets in 2 seconds    ports: 21, 22, 23, 25, 80, 443
responses: no reply for 21, 22, 23, 25, 80; SYN-ACK (open) for 443
```

## STAGE 3 Make a Security Decision

Turn evidence into a defensible recommendation

**What can you confirm? (at least three facts from your scans and the evidence files)**

**What is uncertain? (for example, what an open port proves and does not prove)**

**What do you recommend? Give one firewall change, one monitoring step, and one rule for when services like 8080 are allowed.**

## STAGE 4 AP-Style Questions

Transfer what you learned to a new situation

**1.** A scan of port 8080 on a lab computer reports **closed**. After a student starts a Python web server, the same scan reports **open**.

**Which statement best explains the difference?**

- **A.** The firewall was turned off
- **B.** The computer was compromised
- **C.** A service began listening on port 8080
- **D.** The port number changed

Original practice material - not reproduced from College Board.

**2.** An analyst reviews this packet exchange.

```
1  10.0.5.10:54522 -> 10.0.5.33:8080  [SYN]
2  10.0.5.33:8080 -> 10.0.5.10:54522  [RST, ACK]
```

**Which conclusion is best supported?**

- **A.** No service was listening on port 8080 of 10.0.5.33
- **B.** A secure encrypted session was established
- **C.** The firewall allowed the connection
- **D.** The server accepted the connection and sent a web page

**3.** A firewall's rules are checked from top to bottom, and the first match decides.

| Rule | Action | Protocol | Port | Source |
|---|---|---|---|---|
| 1 | Allow | TCP | 443 | Any |
| 2 | Allow | TCP | 22 | 10.0.5.20 |
| 3 | Deny | TCP | 22 | Any |
| 4 | Allow | TCP | 8080 | 10.0.5.0/24 |
| 5 | Deny | Any | Any | 203.0.113.50 |
| 6 | Deny | Any | Any | Any |

**What happens to TCP port 443 traffic from 203.0.113.50?**

- **A.** It is denied by rule 5
- **B.** It is denied by rule 6
- **C.** It is allowed by rule 4
- **D.** It is allowed by rule 1

**4.** A technician compares two types of Nmap scan.

**Which statement best describes a SYN scan (`-sS`) compared with a TCP connect scan (`-sT`)?**

- **A.** It completes the full handshake and logs more
- **B.** It sends a SYN and, if it receives a SYN-ACK, resets the connection instead of completing the handshake; it usually needs elevated privileges
- **C.** It scans UDP ports only
- **D.** It encrypts the scan so it cannot be detected by any tool

# Evidence Printout

Printed copies of the evidence files, for students without a terminal. The files themselves are in the evidence folder.

### capture_open_port.txt

```
No.  Time      Source       Destination  Proto  Info
1    0.000000  127.0.0.1    127.0.0.1    TCP    54410 -> 8080 [SYN] Seq=0
2    0.000031  127.0.0.1    127.0.0.1    TCP    8080 -> 54410 [SYN, ACK] Seq=0 Ack=1
3    0.000044  127.0.0.1    127.0.0.1    TCP    54410 -> 8080 [ACK] Seq=1 Ack=1
4    0.000162  127.0.0.1    127.0.0.1    HTTP   GET / HTTP/1.1
5    0.000880  127.0.0.1    127.0.0.1    HTTP   HTTP/1.0 200 OK (text/html)
6    0.001210  127.0.0.1    127.0.0.1    TCP    54410 -> 8080 [FIN, ACK]
```

### capture_closed_port.txt

```
No.  Time      Source       Destination  Proto  Info
1    0.000000  127.0.0.1    127.0.0.1    TCP    54522 -> 8080 [SYN] Seq=0
2    0.000025  127.0.0.1    127.0.0.1    TCP    8080 -> 54522 [RST, ACK] Seq=1 Ack=1
```

### firewall_rules.txt

```
Lab network firewall (checked top to bottom, first match wins)

Rule  Action  Direction  Protocol  Port   Source
1     Allow   Inbound    TCP       443    Any
2     Allow   Inbound    TCP       22     10.0.5.20
3     Deny    Inbound    TCP       22     Any
4     Allow   Inbound    TCP       8080   10.0.5.0/24 (lab subnet)
5     Deny    Inbound    Any       Any    203.0.113.50
6     Deny    Inbound    Any       Any    Any
```

### ids_alert.txt

```
IDS ALERT 2026-10-14 09:15:03
signature: PORT_SCAN_SEQUENTIAL
source: 203.0.113.50
destination: 10.0.5.10
packets: 6 SYN packets in 2 seconds
destination ports: 21, 22, 23, 25, 80, 443
responses: no reply for 21, 22, 23, 25, 80; SYN-ACK (open) for 443
action: alert only (no block)
```

**KEY IDEA**

**Before you turn this in:** every answer should name the evidence it comes from (a file name, a line, a time, or a command result). If you are not sure something is proven, write 'not confirmed' and say what evidence would confirm it.